

Simulasi CTF Nasional – Reverse Python dan Web Exploit (Gabungan)

Berikut adalah **Simulasi CTF Nasional – Reverse Python dan Web Exploit (Gabungan)** dengan skenario realistis seperti kompetisi nasional.

Format flag:

NC2026{...}

Durasi: 5–6 Jam

Mode: Jeopardy + Attack-Defense Scenario

Target: SMK tingkat lanjut / Mahasiswa / Seleksi Tim Nasional

STORYLINE: “Operation Shadow API”

Sebuah startup logistik memiliki web API yang bocor.

Tim peserta harus:

1. Reverse source Python backend
2. Temukan bug di web
3. Eksploitasi endpoint
4. Ekstrak flag dari server

Struktur Challenge

shadow-api/

```
|— app.py
|— templates/
|— static/
|— flag.enc
|— requirements.txt
```

Backend menggunakan:

- Flask
- Database SQLite
- Deploy lokal atau via Docker

CHALLENGE 1 – Reverse API Token (Easy)

File: app.py

```
def generate_token(user):  
    return "".join(chr(ord(c)^3) for c in user)  
  
@app.route("/api")  
def api():  
    token=request.args.get("token")  
    if token=="M@f5":  
        return "NC2026{api_access}"
```

Tugas:

- Reverse XOR logic
- Temukan user input yang menghasilkan M@f5

Analisis:

XOR 3 reverse:

$\text{chr}(\text{ord}('M')^3) \rightarrow ?$

Didapat user:

NCe26

Flag:

NC2026{api_access}

CHALLENGE 2 – Source Code Disclosure (Medium)

Server salah konfigurasi, file dapat diakses: <http://target/static/../../app.py>

Teknik:

- Directory traversal

Exploit:

../

Flag ditemukan dalam source:

NC2026{source_leak}

CHALLENGE 3 – Hidden Admin Panel (Medium)

Di dalam source:

```
@app.route("/admin")
def admin():
    if request.headers.get("X-Admin")=="shadow":
        return decrypt_flag()
```

Eksplit:

Gunakan curl atau Burp: X-Admin: shadow

Flag:

NC2026{header_injection}

Tools umum:

- Burp Suite
- Postman

CHALLENGE 4 – SQL Injection + Reverse (Hard)

Kode backend:

```
query=f"SELECT password FROM users WHERE username='{user}'"
```

Eksplit:

```
' OR 1=1--
```

Password yang keluar terenkripsi:

```
aW9kaiZ7d2Vic30=
```

Reverse:

- Base64 decode
- Kurangi 3 setiap karakter

Flag:

NC2026{web_reverse}

CHALLENGE 5 – Flask Debug Exploit (Hard)

Server dijalankan dengan:

```
app.run(debug=True)
```

Eksploit:

- Akses Werkzeug console
- Execute Python

Payload:

```
import os  
os.listdir()
```

Temukan file:

```
flag.enc
```

Decrypt dengan kunci di source.

Flag:

NC2026{debug_rce}

CHALLENGE 6 – JWT Manipulation (Expert)

Backend menggunakan:

- JSON Web Token

Source:

```
jwt.encode({"role":"user"}, "secret123")
```

Peserta:

- Decode JWT
- Ganti role → admin
- Re-sign dengan secret yang ditemukan di source

Flag:

NC2026{jwt_forged}

CHALLENGE 7 – Pickle RCE (Expert)

```
@app.route("/upload", methods=["POST"])  
def upload():  
    data=pickle.loads(request.data)
```

Eksploit:

- Kirim malicious pickle payload

- Reverse shell atau baca file

Flag:

NC2026{pickle_rce}

FINAL BOSS – Full Chain Exploit (Insane)

Langkah:

1. Reverse token generator
2. Bypass login
3. SQL Injection dump secret key
4. Forge JWT
5. Upload malicious pickle
6. Baca /root/flag.txt

Final Flag:

NC2026{shadow_api_compromised}

Format Penilaian Nasional

Gunakan:

- CTFd
- VPS Ubuntu 22.04
- Dockerized challenge per team

Dynamic scoring aktif.

Kompetensi yang Diuji

- ✓ Reverse Python logic
- ✓ Web vulnerability analysis
- ✓ SQL Injection
- ✓ Header manipulation
- ✓ JWT forgery
- ✓ RCE exploitation
- ✓ Source code auditing
- ✓ Crypto reversing

Skill Level

Level	Target Peserta
SMK Advanced	Challenge 1–4
Mahasiswa	1–6
Seleksi Nasional	All

Jika Anda mau, saya bisa lanjutkan dengan:

- Paket ZIP lengkap source vulnerable app
- Panduan setup server Ubuntu + Docker
- Modul latihan 4 minggu sebelum lomba
- Versi Attack-Defense (setiap tim punya server sendiri)
- Versi ultra hard seperti kompetisi nasional sungguhan